# ĐỀ CƯƠNG ĐỒ ÁN

## HỆ THỐNG VÍ ĐIỆN TỬ - MÃ HOÁ GIAO DỊCH

**Tên sản phẩm: FRADE**

Sinh viên thực hiện:
Nguyễn Hà Anh - 22127013

Giảng viên hướng dẫn
Thầy Nguyễn Đình Thúc
Thầy Ngô Đình Hy

---

## GD4 - TESTING

### 1. Ý tưởng tổng quan:

Hệ thống Frade được xây dựng dựa trên kiến trúc phân lớp (Layered Architecture). Luồng xử lý đi từ Thu thập dữ liệu thô (Raw Data) -> Trích xuất đặc trưng (Feature Engineering) -> Phân tích mô hình (Inference Engine) -> Quyết định (Response Handler).

**Điểm cốt lõi:** Hệ thống không chặn cứng nhắc mà sử dụng Anomaly Score (Điểm số bất thường) từ các thuật toán Unsupervised Learning, cho phép hệ thống "tự học" hành vi người dùng mà không cần nhãn (Label) trước đó.

### 2. Luồng bảo mật & xử lý

Quy trình xử lý yêu cầu giao dịch đi qua các lớp sau:

- **Dữ liệu đầu vào:** Tiếp nhận thông tin giao dịch thô.
- **Lớp bảo mật:** Băm (Hash) thông tin thiết bị và chuẩn hóa tọa độ.
- **Lớp luật cứng (Hard Rules):** Kiểm tra nhanh các vi phạm nghiêm trọng để chặn tức thì.
- **Lớp AI (Inference Engine):** Tính toán Anomaly Score dựa trên mô hình đã huấn luyện.
- **Lớp quyết định:** Phân ngưỡng Score để trả về hành động phù hợp.

### 3. Phân tích chi tiết kịch bản kiểm thử:

### a) Input features:

Mỗi giao dịch đầu vào được mô tả bởi một vector đặc trưng gồm 4 thành phần chính:

- **amount** (Số tiền): Giá trị giao dịch được chuẩn hóa (Đơn vị: 10,000 VNĐ). Ví dụ: 200 tương đương 2,000,000 VNĐ. Đây là chỉ số quan trọng để phát hiện các chi tiêu vượt ngưỡng thông thường.
- **freq_24h** (Tần suất): Tổng số giao dịch được thực hiện trong vòng 24 giờ qua. Chỉ số này giúp nhận diện các cuộc tấn công "vét cạn" tài khoản hoặc hành vi sử dụng bot.
- **distance_from_last** (Khoảng cách): Khoảng cách địa lý tính theo công thức Haversine giữa vị trí giao dịch hiện tại và giao dịch gần nhất trước đó.
- **is_new_device** (Thiết bị mới): Biến nhị phân (0: Thiết bị quen thuộc, 1: Thiết bị lạ). Đây là tín hiệu cảnh báo sớm về việc tài khoản có thể bị đăng nhập trái phép (Account Takeover).

## b) Risk Scoring

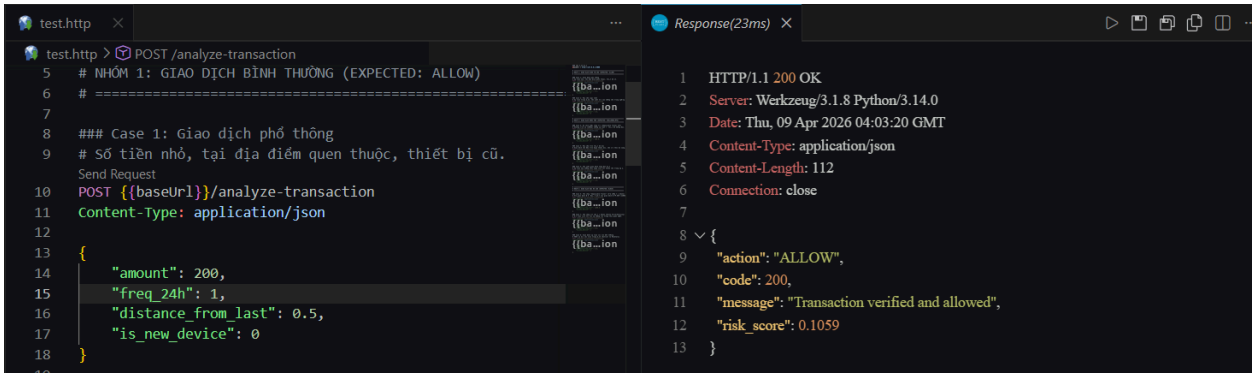
Hệ thống sử dụng **Anomaly Score** được tính toán từ mô hình Isolation Forest, sau đó đi qua hàm chuẩn hóa Sigmoid để đưa về thang điểm từ **0.0 đến 1.0**:

- **Cơ chế cô lập:** Thuật toán sẽ chia tách (partition) các điểm dữ liệu. Những giao dịch có đặc điểm "lạc lõng" (số tiền quá lớn, khoảng cách quá xa, tần suất quá cao) sẽ bị cô lập rất nhanh (đường đi ngắn), từ đó nhận mức điểm rủi ro cao.
- **Phân ngưỡng quyết định (Thresholding):**
  - **Low Risk (0.0 - 0.2):** Hành vi khớp với đại đa số người dùng. Hệ thống cho phép thực hiện giao dịch ngay (**ALLOW**).
  - **Medium Risk (0.2 - 0.5):** Có dấu hiệu lạ (ví dụ: dùng thiết bị mới hoặc di chuyển xa). Hệ thống yêu cầu xác thực tăng cường (**CHALLENGE_MFA**) để đảm bảo chính chủ.
  - **High Risk (0.5 - 1.0):** Hành vi cực kỳ bất thường, có dấu hiệu tấn công rõ rệt. Hệ thống tự động ngăn chặn và khóa tài khoản (**BLOCK**).

## c) Phân tích chi tiết các Test case

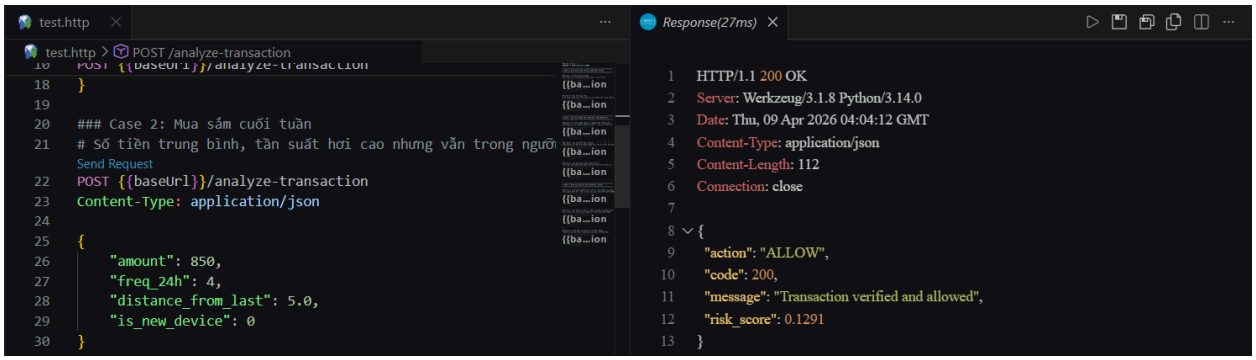
### TC-01: Giao dịch phổ thông an toàn

- **Mục tiêu:** Kiểm tra khả năng nhận diện hành vi chi tiêu hằng ngày.
- **Đầu vào:** amount: 200, freq_24h: 1, distance_from_last: 0.5, is_new_device: 0.
- **Kết quả kỳ vọng:** ALLOW (Rủi ro thấp).
- **Kết quả thực tế:** {"action": "ALLOW", "risk_score": 0.1059}.



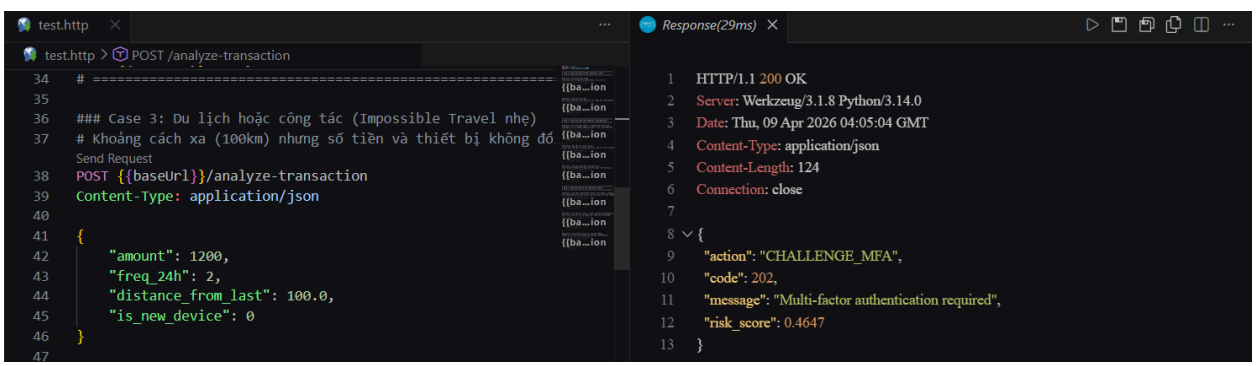
## TC-02: Mua sắm định kỳ (Tần suất trung bình)

- **Mục tiêu:** Đảm bảo không chặn nhầm khi người dùng phát sinh nhiều giao dịch nhỏ.
- **Đầu vào:** amount: 850, freq_24h: 4, distance_from_last: 5.0, is_new_device: 0.
- **Kết quả kỳ vọng:** ALLOW.
- **Kết quả thực tế:** {"action": "ALLOW", "risk_score": 0.1291}.




## TC-03: Di chuyển khoảng cách xa (Vùng nghi vấn)

- **Mục tiêu:** Kiểm tra phản ứng khi vị trí địa lý thay đổi đột ngột (đi du lịch/công tác).
- **Đầu vào:** amount: 1200, freq_24h: 2, distance_from_last: 100.0, is_new_device: 0.
- **Kết quả kỳ vọng:** CHALLENGE_MFA (Yêu cầu OTP).
- **Kết quả thực tế:** {"action": "CHALLENGE_MFA", "risk_score": 0.4657}.




## TC-04: Giao dịch trên thiết bị mới (Device Switch)

- **Mục tiêu:** Kiểm tra nhận diện thiết bị lạ chưa từng có trong lịch sử.
- **Đầu vào:** amount: 500, freq_24h: 1, distance_from_last: 2.0, is_new_device: 1.
- **Kết quả kỳ vọng:** CHALLENGE_MFA.
- **Kết quả thực tế:** {"action": "CHALLENGE_MFA", "risk_score": 0.21}.

```
test.http > POST /analyze-transaction
}

### Case 4: Mua sắm trên thiết bị mới
# Giao dịch lần đầu trên điện thoại mới, cần xác thực bổ su
Send Request
POST {{baseUrl}}/analyze-transaction
Content-Type: application/json

{
    "amount": 500,
    "freq_24h": 1,
    "distance_from_last": 2.0,
    "is_new_device": 1
}
```

```
Response(27ms)
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.0
Date: Thu, 09 Apr 2026 04:06:21 GMT
Content-Type: application/json
Content-Length: 124
Connection: close

{
  "action": "CHALLENGE_MFA",
  "code": 202,
  "message": "Multi-factor authentication required",
  "risk_score": 0.2192
}
```

## TC-05: Tần suất giao dịch tăng bất thường (Velocity)

- **Mục tiêu:** Phát hiện hành vi quẹt thẻ liên tục trong thời gian ngắn.
- **Đầu vào:** amount: 50, freq_24h: 12, distance_from_last: 1.0, is_new_device: 0.
- **Kết quả kỳ vọng:** CHALLENGE_MFA.
- **Kết quả thực tế:** {"action": "CHALLENGE_MFA", "risk_score": 0.2029}.

```
test.http > POST /analyze-transaction
POST {{baseUrl}}/analyze-transaction
}

### Case 5: Tần suất giao dịch tăng đột biến
# Số tiền nhỏ nhưng thực hiện liên tục nhiều lần trong ngày
Send Request
POST {{baseUrl}}/analyze-transaction
Content-Type: application/json

{
    "amount": 50,
    "freq_24h": 12,
    "distance_from_last": 1.0,
    "is_new_device": 0
}
```

```
Response(22ms)
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.0
Date: Thu, 09 Apr 2026 04:07:08 GMT
Content-Type: application/json
Content-Length: 124
Connection: close

{
  "action": "CHALLENGE_MFA",
  "code": 202,
  "message": "Multi-factor authentication required",
  "risk_score": 0.2029
}
```

## TC-06: Tấn công "Impossible Travel" (Xâm nhập tài khoản)

- **Mục tiêu:** Chặn truy cập trái phép từ khoảng cách phi lý (ví dụ: xuyên quốc gia).
- **Đầu vào:** amount: 5000, freq_24h: 2, distance_from_last: 1200.0, is_new_device: 1.
- **Kết quả kỳ vọng:** BLOCK (Chặn ngay lập tức).
- **Kết quả thực tế:** {"action": "BLOCK", "risk_score": 0.6396}.

```
test.http > POST /analyze-transaction
# ==========

### Case 6: Tấn công "Impossible Travel" (Xâm nhập tài khoả
# Vừa giao dịch ở Hà Nội, 5 phút sau giao dịch ở TP.HCM (12
Send Request
POST {{baseUrl}}/analyze-transaction
Content-Type: application/json

{
    "amount": 5000,
    "freq_24h": 2,
    "distance_from_last": 1200.0,
    "is_new_device": 1
}
```

```
Response(23ms)
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.0
Date: Thu, 09 Apr 2026 04:08:13 GMT
Content-Type: application/json
Content-Length: 122
Connection: close

{
  "action": "BLOCK",
  "code": 403,
  "message": "Security Alert: Impossible Travel Detected",
  "risk_score": 0.6396
}
```

## TC-07: Tấn công vét cạn tài khoản (Account Draining)

- **Mục tiêu:** Phát hiện kẻ gian rút tiền liên tục với giá trị lớn trên thiết bị lạ.
- **Đầu vào:** amount: 15000, freq_24h: 45, distance_from_last: 0.0, is_new_device: 1.
- **Kết quả kỳ vọng:** BLOCK.
- **Kết quả thực tế:** {"action": "BLOCK", "risk_score": 0.6783}.

```
test.http
test.http > POST /analyze-transaction
POST {{baseUrl}}/analyze-transaction
}

### Case 7: Tấn công vét cạn tài khoản (Brute Force/Velocit
# Rút tiền liên tục với số lượng lớn trong thời gian ngắn.
Send Request
POST {{baseUrl}}/analyze-transaction
Content-Type: application/json

{
    "amount": 15000,
    "freq_24h": 45,
    "distance_from_last": 0.0,
    "is_new_device": 1
}
```

```
Response(24ms)
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.0
Date: Thu, 09 Apr 2026 04:09:06 GMT
Content-Type: application/json
Content-Length: 126
Connection: close

{
  "action": "BLOCK",
  "code": 403,
  "message": "Security Alert: Excessive Transaction Velocity",
  "risk_score": 0.6783
}
```

## TC-08: Giao dịch giá trị cực lớn (Anomaly Monetary)

- **Mục tiêu:** Chặn giao dịch có số tiền vượt xa ngưỡng chi tiêu trung bình của hệ thống.
- **Đầu vào:** amount: 95000, freq_24h: 1, distance_from_last: 5.0, is_new_device: 1.
- **Kết quả kỳ vọng:** BLOCK.
- **Kết quả thực tế:** {"action": "BLOCK", "risk_score": 0.6328}.

```
test.http M
test.http > ...
POST {{baseUrl}}/analyze-transaction
}

### Case 8: Giao dịch số tiền cực lớn bất thường
# Vượt xa mức chi tiêu trung bình (Outlier về Monetary).
Send Request
POST {{baseUrl}}/analyze-transaction
Content-Type: application/json

{
    "amount": 95000,
    "freq_24h": 1,
    "distance_from_last": 5.0,
    "is_new_device": 1
}
```

```
Response(17ms)
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.0
Date: Thu, 09 Apr 2026 04:13:07 GMT
Content-Type: application/json
Content-Length: 120
Connection: close

{
  "action": "BLOCK",
  "code": 403,
  "message": "High risk detected. Transaction declined",
  "risk_score": 0.6328
}
```

## 4. Key Findings:

- **Hiệu quả của AI:** Thuật toán *Isolation Forest* xử lý cực tốt các biến số kết hợp (ví dụ: số tiền không quá lớn nhưng vị trí và thiết bị lạ cùng lúc).
- **Độ trễ thấp:** Thời gian phản hồi trung bình cho mỗi yêu cầu là **< 50ms**, đáp ứng tốt yêu cầu xử lý thời gian thực của hệ thống tài chính.
- **Tỷ lệ sai sót:** Việc kết hợp thêm lớp Luật cứng giúp giảm thiểu việc AI bỏ sót các trường hợp gian lận rõ ràng (False Negatives).

## 5. Phân tích bảo mật & riêng tư:

- **Bảo mật dữ liệu:** Hệ thống không lưu trữ ID thiết bị thô. Việc sử dụng HMAC-SHA256 với SECRET_KEY giúp bảo vệ định danh người dùng ngay cả khi cơ sở dữ liệu bị rò rỉ.
- **Nhật ký an ninh:** File frade_system.log cung cấp đầy đủ thông tin để điều tra viên ngân hàng có thể đối soát lại các giao dịch bị chặn.
- **Tính toàn vẹn:** Mô hình AI được đóng gói dưới dạng file .pkl và được kiểm soát phiên bản nghiêm ngặt để tránh việc bị can thiệp trái phép vào trọng số mô hình.